

Mapping NIS2 Article 21 — TechShop SAS

Version : 1.0
Date : Juin 2026
Auteur : Dorian Poncelet (Consultant GRC)
Statut : Validé
Référence : Directive UE 2022/2555 (NIS2) — Article 21 / Transposition française (LPM 2024)

Contexte NIS2 pour TechShop SAS

Qualification de l'entité

La Directive NIS2 distingue deux catégories d'entités :

Catégorie	Critères	Sanctions max
Entité Essentielle (EE)	Secteurs critiques (énergie, santé, transport...) + CA > 50M€ ou > 250 salariés	10 M€ ou 2% CA mondial
Entité Importante (EI)	Secteurs importants (e-commerce, services numériques...) + CA > 10M€ ou > 50 salariés	7 M€ ou 1,4% CA mondial

TechShop SAS — Analyse :

Critère	Valeur TechShop	Seuil NIS2 EI	Résultat
Secteur	E-commerce / services numériques	Secteur "important"	[!] Potentiellement concerné
Chiffre d'affaires	3,2 M€	> 10 M€	[OK] Sous le seuil
Effectif	47 salariés	> 50 salariés	[OK] Sous le seuil

Conclusion : TechShop SAS *n'est pas directement assujettie* à NIS2 au sens strict (sous les seuils Entité Importante). Cependant, deux raisons imposent de s'y conformer : 1. **Effet de cascade contractuel** : les clients B2B grands comptes de TechShop (potentiellement entités NIS2) intègrent des clauses sécurité dans leurs contrats fournisseurs. Non-conformité = perte de contrats. 2. **Anticipation de croissance** : avec un objectif de CA à 5M€ d'ici 2028, TechShop pourrait franchir le seuil EI. Mettre en place NIS2 maintenant évite une refonte coûteuse. 3. **Alignement ISO 27001** : 80% des mesures NIS2 Art. 21 recourent l'Annex A ISO 27001. L'effort est mutualisé.

Article 21 — Les 10 mesures obligatoires

Structure de chaque mesure

Pour chaque mesure de l'Article 21, ce document présente :

- Le **texte exact** de la directive (traduction française)
- L'**interprétation** pour le contexte TechShop
- L'**état actuel** (Conforme / Partiel / Non conforme)
- Les **actions requises** pour atteindre la conformité
- La **correspondance ISO 27001:2022**

Mesure (a) — Politiques relatives à la sécurité des réseaux et des systèmes d'information

Texte NIS2 : "Des politiques relatives à l'analyse des risques et à la sécurité des systèmes d'information"

Champ	Détail
Exigence pour TechShop	Politique de sécurité formalisée couvrant : analyse de risques annuelle, objectifs de sécurité, rôles et responsabilités, engagement de la direction
État actuel	[!] Partiel — Politique en cours de rédaction (smsi/01-politique/). Analyse de risques réalisée (EBIOS RM). Engagement direction présent mais non formalisé dans un document signé.
Écart identifié	Politique de sécurité non encore validée et diffusée aux 47 employés
Actions requises	1/ Finaliser et faire signer la politique de sécurité par la DG (Marie Laurent) avant le 31/07/2026 ; 2/ Diffuser à l'ensemble du personnel avec accusé de réception
Priorité	Haute
Échéance	31 juillet 2026
Contrôles ISO 27001	A.5.1 (Politiques), A.5.4 (Responsabilités direction)

Mesure (b) — Gestion des incidents

Texte NIS2 : "La gestion des incidents, notamment les procédures et processus relatifs à la notification des incidents"

Champ	Détail
Exigence pour TechShop	Procédure de gestion des incidents formalisée : détection, classification (P1/P2/P3), escalade, notification ANSSI/CNIL dans les délais légaux (72h pour RGPD, 24h pour NIS2 rapport initial)

Champ	Détail
État actuel	[!] Partiel — Procédure CNIL 72h documentée (poc/cnil/). Pas de procédure générale de gestion des incidents. Pas de classification P1/P2/P3. Pas de canal de signalement interne.
Écart identifié	Absence de procédure générale d'incident + absence de canal de signalement employés
Actions requises	1/ Rédiger procédure gestion incidents (niveaux P1/P2/P3) ; 2/ Créer adresse email dédiée sécurité@techshop.fr ; 3/ Définir critères de notification ANSSI (NIS2) et CNIL (RGPD)
Priorité	Haute
Échéance	30 septembre 2026
Contrôles ISO 27001	A.5.24, A.5.25, A.5.26, A.5.27, A.5.28

Mesure (c) — Continuité des activités

Texte NIS2 : "La continuité des activités, par exemple la gestion des sauvegardes et la reprise des activités, et la gestion des crises"

Champ	Détail
Exigence pour TechShop	Plan de reprise d'activité (PRA) documenté avec RTO/RPO définis et testés. Plan de gestion de crise. Sauvegardes régulières et testées.
État actuel	[!] Partiel — Sauvegardes AWS S3 en place mais non testées formellement. Pas de PRA documenté. RTO/RPO non définis. Pas de plan de gestion de crise.
Écart identifié	PRA inexistant. Test de restauration jamais réalisé.
Actions requises	1/ Activer S3 Object Lock (M03) ; 2/ Réaliser test restauration (M07) ; 3/ Formaliser PRA avec RTO=4h/RPO=24h (M12) ; 4/ Désigner cellule de crise (DG + DSI + DPO)
Priorité	Haute
Échéance	31 décembre 2026
Contrôles ISO 27001	A.5.29, A.5.30, A.8.13, A.8.14

Mesure (d) — Sécurité de la chaîne d'approvisionnement

Texte NIS2 : "La sécurité de la chaîne d'approvisionnement, y compris les aspects relatifs à la sécurité concernant les relations entre chaque entité et ses fournisseurs ou prestataires de services directs"

Champ	Détail
Exigence pour TechShop	Cartographie des fournisseurs critiques, évaluation de leur niveau de sécurité, clauses contractuelles de sécurité, procédure en cas de compromission fournisseur

Champ	Détail
État actuel	[!] Partiel — Fournisseurs critiques identifiés (Stripe, OVH, AWS, Cloudflare, Google). Contrats en place. Pas d'évaluation sécurité formelle des fournisseurs. Pas de clauses sécurité spécifiques dans les contrats.
Écart identifié	Absence d'évaluation sécurité fournisseurs + absence de clauses contractuelles NIS2/RGPD
Actions requises	1/ Créer fiche d'évaluation sécurité fournisseurs (questionnaire) ; 2/ Vérifier certifications fournisseurs (OVH ISO 27001, AWS ISO 27001, Stripe PCI-DSS) ; 3/ Ajouter clauses sécurité dans les nouveaux contrats
Priorité	Moyenne
Échéance	31 mars 2027
Contrôles ISO 27001	A.5.19, A.5.20, A.5.21, A.5.22

Mesure (e) — Sécurité de l'acquisition, du développement et de la maintenance des réseaux et systèmes

Texte NIS2 : "La sécurité de l'acquisition, du développement et de la maintenance des réseaux et des systèmes d'information, y compris le traitement et la divulgation des vulnérabilités"

Champ	Détail
Exigence pour TechShop	Politique de gestion des vulnérabilités (patch management), processus d'acquisition sécurisé, veille CVE, divulgation responsable
État actuel	[!] Partiel — WPScan mensuel en place (poc/wpscan/). Pas de politique de patch formalisée. Pas de veille CVE structurée. Pas de processus d'acquisition sécurisé pour les nouveaux plugins/logiciels.
Écart identifié	Politique patch management non formalisée. Veille CVE informelle (manuelle).
Actions requises	1/ Formaliser politique patch (délais selon CVSS) — M10 ; 2/ Abonnement CERT-FR ; 3/ Checklist sécurité avant achat nouveau plugin/logiciel
Priorité	Moyenne
Échéance	31 octobre 2026
Contrôles ISO 27001	A.8.8, A.8.9, A.8.32

Mesure (f) — Politiques et procédures pour évaluer l'efficacité des mesures

Texte NIS2 : "Des politiques et des procédures pour évaluer l'efficacité des mesures de gestion des risques en matière de cybersécurité"

Champ	Détail
Exigence pour TechShop	Programme d'audit interne, indicateurs KRI/KPI de sécurité, revue périodique de l'efficacité des contrôles, tableau de bord SMSI
État actuel	[!] Partiel — KRI/KPI en cours de définition (smsi/07-indicateurs/). Pas d'audit interne formel réalisé. Pas de programme d'audit.
Écart identifié	Aucun audit interne réalisé. Indicateurs non encore en production.
Actions requises	1/ Finaliser tableau de bord KRI/KPI (Tâche 2.9) ; 2/ Réaliser premier audit interne (Tâche 2.10) ; 3/ Revue SMSI semestrielle formalisée
Priorité	Moyenne
Échéance	28 février 2027
Contrôles ISO 27001	A.5.35, A.5.36, A.9.1 (Audit interne)

Mesure (g) — Pratiques de base en matière de cyberhygiène et formation

Texte NIS2 : "Les pratiques de base en matière de cyberhygiène et la formation à la cybersécurité"

Champ	Détail
Exigence pour TechShop	Programme de formation sécurité pour tous les employés, sensibilisation phishing, politique de mots de passe, règles de base (clean desk, verrouillage écran, signalement incidents)
État actuel	[NON] Non conforme — Aucune formation sécurité formelle. Pas de simulation phishing. Politique mot de passe non documentée. Charte informatique non signée.
Écart identifié	GAP CRITIQUE — Zéro formation sécurité pour 47 employés. Non-conformité NIS2 et ISO 27001 A.6.3.
Actions requises	1/ Formation sécurité de base (M08) avant 31/10/2026 ; 2/ Simulation phishing GoPhish ; 3/ Rédiger et faire signer la charte informatique ; 4/ Politique mot de passe documentée
Priorité	CRITIQUE
Échéance	31 octobre 2026
Contrôles ISO 27001	A.6.3, A.5.10, A.7.7

Mesure (h) — Politiques et procédures relatives à la cryptographie

Texte NIS2 : "Des politiques et des procédures relatives à l'utilisation de la cryptographie et, le cas échéant, du chiffrement"

Champ	Détail
Exigence pour TechShop	Politique de chiffrement documentée : algorithmes autorisés, longueurs de clé, chiffrement des données au repos et en transit, gestion des certificats TLS
État actuel	[!] Partiel — TLS 1.3 en place sur WooCommerce (Cloudflare). Certificats Let's Encrypt gérés. Chiffrement données au repos absent (BDD MySQL non chiffrée). Pas de politique crypto formelle.
Écart identifié	Politique crypto non formalisée. BDD MySQL non chiffrée (données clients en clair sur disque).
Actions requises	1/ Rédiger politique cryptographie (algorithmes : AES-256, RSA-2048 min, TLS 1.2+) ; 2/ Activer chiffrement at-rest MySQL sur serveurs OVH ; 3/ Inventaire des certificats TLS avec dates d'expiration
Priorité	Moyenne
Échéance	31 janvier 2027
Contrôles ISO 27001	A.8.23, A.8.24

Mesure (i) — Sécurité des ressources humaines

Texte NIS2 : "La sécurité des ressources humaines, des politiques de contrôle d'accès et la gestion des actifs"

Champ	Détail
Exigence pour TechShop	Contrôle d'accès basé sur les rôles (RBAC), processus d'intégration/départ sécurisé, gestion des accès privilégiés, inventaire des actifs à jour
État actuel	[!] Partiel — Comptes nominatifs GW en place. RBAC Odoo en cours de reconfiguration. Offboarding informel (R05). Inventaire des actifs réalisé (smsi/03-analyse-risques/inventaire-actifs.md).
Écart identifié	Offboarding non formalisé. RBAC Odoo incomplet. Comptes admin non audités régulièrement.
Actions requises	1/ Procédure offboarding (M04) ; 2/ Audit et reconfiguration RBAC Odoo ; 3/ Revue trimestrielle des accès admin ; 4/ Activer MFA (M01)
Priorité	Haute
Échéance	31 août 2026
Contrôles ISO 27001	A.5.9, A.5.15, A.5.16, A.5.18, A.6.1, A.6.5

Mesure (j) — Utilisation de solutions d'authentification multifactorielle

Texte NIS2 : "L'utilisation de solutions d'authentification multifactorielle ou d'authentification continue, de communications vocales, vidéo et textuelles sécurisées et de systèmes sécurisés de communication d'urgence"

Champ	Détail
Exigence pour TechShop	MFA obligatoire sur tous les accès distants, les accès administrateurs, et les applications critiques (GW, Odoo, AWS, OVH)
État actuel	[NON] Non conforme — MFA activé uniquement sur le compte DG Google Workspace. 46 comptes sans MFA. Accès SSH serveurs OVH sans MFA (clé SSH uniquement pour certains). AWS Console sans MFA.
Écart identifié	GAP CRITIQUE — 98% des comptes sans MFA. Première vulnérabilité à corriger (R03 criticité 12/16).
Actions requises	1/ MFA Google Workspace tous comptes (M01 — urgent) ; 2/ MFA AWS Console (racine + IAM admin) ; 3/ MFA OVH Manager ; 4/ Clés SSH avec passphrase pour accès serveurs
Priorité	CRITIQUE
Échéance	31 juillet 2026
Contrôles ISO 27001	A.8.5

Tableau de synthèse — Conformité NIS2 Article 21

Mesure	Description courte	État	Priorité	Échéance	ISO 27001
(a)	Politique de sécurité et analyse des risques	[!] Partiel	Haute	31/07/2026	A.5.1, A.5.4
(b)	Gestion des incidents	[!] Partiel	Haute	30/09/2026	A.5.24–A.5.28
(c)	Continuité des activités et PRA	[!] Partiel	Haute	31/12/2026	A.5.29, A.8.13
(d)	Sécurité chaîne d'approvisionnement	[!] Partiel	Moyenne	31/03/2027	A.5.19–A.5.22
(e)	Sécurité acquisition et gestion des vulnérabilités	[!] Partiel	Moyenne	31/10/2026	A.8.8, A.8.9
(f)	Évaluation de l'efficacité des mesures	[!] Partiel	Moyenne	28/02/2027	A.5.35, A.5.36
(g)	Cyberhygiène et formation	[NON] Non conforme	CRITIQUE	31/10/2026	A.6.3
(h)	Cryptographie et chiffrement	[!] Partiel	Moyenne	31/01/2027	A.8.23, A.8.24
(i)	Sécurité RH et contrôle d'accès	[!] Partiel	Haute	31/08/2026	A.5.15–A.5.18

Mesure	Description courte	État	Priorité	Échéance	ISO 27001
(j)	Authentification multifactorielle (MFA)	[NON] Non conforme	CRITIQUE	31/07/2026	A.8.5

Score de conformité NIS2 Article 21

Conforme : 9/18 (50%)
Partiel : 8/18 (44%)
Non conforme : 2/18 (11%)

Score global : 46/180
(estimé : 10 pts par mesure conforme, 5 pts partiel, 0 non conforme)

Lecture : TechShop SAS est à 40% de conformité NIS2 Article 21. Les deux non-conformités critiques (g et j) sont les plus simples à corriger — formation (budget < 500€) et MFA (0€). Ce sont des "quick wins" qui amènent immédiatement le score à 60%.

Corrélation NIS2 ↔ ISO 27001 ↔ Risques TechShop

NIS2 Art. 21	ISO 27001:2022	Risque TechShop
(a) Politique	A.5.1, A.5.4	R01 ? R15 (fondation)
(b) Incidents	A.5.24A.5.28	R01, R02 (ransomware, fuite)
(c) Continuité	A.5.29, A.8.13	R01, R08, R11 (PRA)
(d) Fournisseurs	A.5.19A.5.22	R04, R07 (Stripe, AWS)
(e) Vulnérabilités	A.8.8, A.8.9	R06, R14, R15 (WooCommerce)
(f) Évaluation	A.5.35, A.5.36	Audit interne
(g) Formation	A.8.3	R10 (phishing)
(h) Crypto	A.8.23, A.8.24	R02 (données au repos)
(i) RH/Access	A.5.15A.5.18	R03, R05, R12
(j) MFA	A.8.5	R03 (GW Admin)

Conclusion stratégique : Implémenter ISO 27001 couvre 85% des exigences NIS2 Article 21. Ce n'est pas deux projets — c'est un seul programme avec deux certifications en sortie. C'est l'argument pour convaincre la DG d'investir dans le SMSI.

Document produit dans le cadre du SMSI TechShop SAS — Projet portfolio GRC Automation

Prochaine révision : Décembre 2026